

Sentinel AI — Comprehensive System Context for AI Models

Executive Summary

Sentinel AI is an enterprise security platform that discovers, classifies, and reports on shadow AI (unauthorized or uncontrolled AI tools and agents) within organizations' cloud environments. It provides visibility into AI tool usage, risk assessment, and compliance documentation for Microsoft 365 and Google Workspace environments.

****Core Value Proposition****: See every AI tool in your organization. Control what it can do. Prove it to regulators.

1. The Problem Statement

Shadow AI Crisis

Organizations face a critical blind spot: employees are rapidly adopting AI tools (ChatGPT, Claude, GitHub Copilot, etc.) without IT approval or oversight. This creates:

- ****Visibility Gap****: IT teams have no idea what AI tools are being used - ****Security Risk****: Unknown AI tools may have excessive permissions to sensitive data (email, files, employee records) - ****Compliance Risk****: Uncontrolled AI usage violates EU AI Act, SOC 2, GDPR, and other regulatory requirements - ****Data Leakage****: Employees unknowingly send proprietary data to external AI services - ****Governance Failure****: No way to enforce policy or track what AI agents can access

Target Pain Points (Enterprise CISOs, Security Leaders)

1. Can't audit AI tool usage or access patterns 2. No way to distinguish "safe" approved tools from risky unknown apps 3. Can't demonstrate compliance to auditors/regulators 4. Can't enforce permissions or revoke access systematically 5. MCP agents (Model Context Protocol agents) running autonomously with broad permissions

2. What Sentinel AI Does

Core Functionality

****Discovery Phase****: - Scans Microsoft 365 environment (Azure AD, registered apps, service principals, OAuth-connected apps) - Scans Google Workspace environment (Drive integrations, Google Apps Scripts, marketplace apps, OAuth permissions) - Identifies both applications and user-level risk signals - No software installation required; uses OAuth-delegated authentication

****Classification Phase****: - Risk-scores each discovered AI tool using whitelist-enhanced algorithm - Compares registered permissions against actual 30-day usage patterns - Identifies over-privileged applications (have permissions they don't use) - Detects autonomous agents (MCP agents, workflow automation tools) - Flags unknown apps with sensitive permissions

****Reporting Phase****: - Generates professional PDF report with executive summary - Lists all discovered AI assets by risk level (HIGH/MEDIUM/LOW) - Includes specific remediation recommendations - Maps findings to compliance frameworks (EU AI Act, SOC 2, etc.) - Provides compliance attestation ready for auditors

Key Features

1. ****Shadow AI Discovery**** — Detects AI tools installed without IT approval 2. ****MCP Agent Detection**** — Identifies autonomous AI agents and their permission scope 3. ****Risk Scoring**** — Whitelist-enhanced classification (safe tools vs. unknown risks) 4. ****Permission Waste Analysis**** — Compares registered vs. actual usage over 30 days 5. ****Dual Platform Coverage**** — Microsoft 365 + Google Workspace in one unified report 6. ****Compliance Ready**** — Findings mapped to regulatory requirements

3. Technical Architecture

System Components

****Location****: `/scanner` directory

****Modules****: - `scanner/microsoft.py` — Microsoft 365 Graph API integration - Scans registered applications (`/applications`) - Scans service principals and AI agents (`/servicePrincipals`) - Scans user license allocation (risk signal for elevated access) - Pulls audit logs for actual permission usage patterns

- `scanner/google.py` — Google Workspace API integration - Scans Google Drive third-party app integrations - Scans Google Apps Scripts (automation/integration points) - Scans marketplace app installations - Detects file sharing patterns from external AI services - Uses OAuth refresh tokens to access credentials server-side

- `scanner/risk\_scorer.py` — Risk classification engine - Whitelist lookup system for known tools - Over-permissioning detection (has permissions it doesn't use) - Risk level assignment (HIGH/MEDIUM/LOW) - Generation of risk reasons (explanatory text for findings)

- `db.py` — Supabase database integration - Persists scan results to Supabase - Manages customer credentials (tenant IDs, refresh tokens) - Stores AI asset inventory with risk levels - Tracks scan request processing pipeline

- `run\_scan.py` — Orchestrator for automated scanning - Pulls pending scan requests from Supabase - Fetches customer credentials from database - Runs Microsoft and Google scans with customer's credentials - Scores assets and generates PDF report - Updates scan status (processing -> completed/failed)

****Location**:** `/website` directory

****Architecture**:** - ****Framework**:** Next.js 15 App Router with TypeScript - ****Database**:** Supabase (PostgreSQL + Auth + Storage) - ****Styling**:** Inline CSS (no Tailwind) - ****Auth**:** Supabase Auth with magic link and email/password flows

****Key Pages**:** - `/app/page.tsx` — Marketing homepage with full-screen sections - `/app/dashboard/page.tsx` — Customer dashboard showing scan overview - `/app/auth/login`, `/signup`, `/forgot-password` — Authentication flows - `/app/dashboard/assets` — AI assets inventory table - `/app/dashboard/reports` — Historical scan reports with downloads - `/app/dashboard/settings` — Account and environment connection settings

****OAuth Integration**** (for connecting customer environments): - `/app/auth/microsoft/callback` — Microsoft 365 OAuth callback - Receives tenant_id from Microsoft admin consent flow - Stores tenant_id in customers table - Triggers scan request if both Microsoft and Google connected

- `/app/auth/google/callback` — Google Workspace OAuth callback - Server-side code exchange with Google (protects client_secret) - Stores refresh_token in customers table for later access - Triggers scan request if both Microsoft and Google connected

****Dashboard Components**:** - `Sidebar` — Navigation (Overview, Assets, Reports, Settings) - `ConnectEnvironment` — Shows connection status for both platforms - `RiskScoreCard` — Displays overall risk score visualization - `AssetSummaryCards` — Top-level stats (total assets, high-risk count, MCP agents) - `PlatformBadge`, `RiskBadge` — Visual indicators for assets

****User Flows**:** 1. Signup/Login -> Dashboard 2. Dashboard -> Connect Microsoft 365 (OAuth) 3. Dashboard -> Connect Google Workspace (OAuth) 4. Both connected -> Scan request submitted 5. Scan runs (automated) -> Results appear in dashboard 6. Download PDF report from Reports page

****Core Tables**:**

- `customers` (multi-tenant) - id (UUID, PK) - company_name - microsoft_tenant_id (nullable) - microsoft_connected (boolean) - google_refresh_token (nullable) - google_connected (boolean) - created_at, updated_at

- `users` — Supabase Auth users table (auto-managed) - id (UUID, FK to auth.users) - email - created_at

- `user\_customer\_map` — Many-to-one relationship - user_id (FK to users) - customer_id (FK to customers) - Links users to their organization's customer record

- `scan\_requests` — Scan job queue - id (UUID, PK) - customer_id (FK) - status (pending | processing | completed | failed) - created_at, updated_at

- `scans` — Completed scan records - id (UUID, PK) - customer_id (FK) - status (completed) - started_at, completed_at - total_assets_found (integer) - high_risk_count, medium_risk_count, low_risk_count (integers)

- `ai\_assets` — Individual asset records from scans - id (UUID, PK) - scan_id (FK) - asset_name (string) - asset_type (enum: AI Tool, MCP Agent, Google Apps Script, User Risk Signal, etc.) - platform (string: Microsoft 365, Azure AD, Google Workspace, Google Drive) - risk_level (enum: HIGH, MEDIUM, LOW) - risk_reason (text: explanation of risk) - permissions (string: number of registered permissions) - data_access (string: actual usage notes)

- `scan\_reports` — PDF report metadata - id (UUID, PK) - scan_id (FK) - file_path (string: path in Supabase Storage) - file_name (string) - created_at

- `scan\_reports` bucket (Supabase Storage) - PDFs stored at: `{customer\_id}/{scan\_id}/report.pdf`

****Row-Level Security (RLS)**:** - Users can only see their own customer's data - Service role bypass for automated scanner operations

4. Data Flow: End-to-End Workflow

``` 1. SIGNUP User signs up -> Supabase Auth creates user record User maps to customer record via user\_customer\_map

2. CONNECT ENVIRONMENTS User clicks "Connect Microsoft 365" -> Redirects to Microsoft OAuth Microsoft OAuth -> Callback stores tenant\_id User clicks "Connect Google Workspace" -> Redirects to Google OAuth Google OAuth -> Server-side code exchange -> Stores refresh\_token Both connected -> scan\_requests row created with status='pending'

3. AUTOMATED SCANNING Background job (run\_scan.py) polls for pending scan requests For each pending request: - Fetch customer credentials from database - Update status to 'processing' - Run Microsoft scan (uses tenant\_id to call Microsoft Graph) - Run Google scan (uses refresh\_token to authorize Google APIs) - Aggregate results into scored\_assets list - Score each asset using whitelist-enhanced risk\_scorer - Generate PDF report with results - Upload PDF to Supabase Storage - Insert scan record with asset counts - Insert ai\_assets rows for each discovered asset - Insert scan\_reports row with PDF path - Update scan\_request status to 'completed'

4. DASHBOARD VIEW Customer logs in -> Sees latest scan results Overview page shows: - Overall risk score - Total assets found - High/Medium/Low breakdown - MCP agents count - Connection status for both platforms Assets page -> Table of all discovered AI tools with risk levels Reports page -> Download links for all past reports

5. REMEDIATION Customer reviews findings Takes action in their environment (disable apps, revoke permissions) Requests new scan to verify remediation ``

## 5. Asset Types and Risk Classification

### Discovered Asset Types

**\*\*Microsoft 365 Specific\*\***: - Registered Applications (AAD-registered apps with OAuth) - Service Principals (automated app access) - User Risk Signals (user accounts with elevated app licenses)

**\*\*Google Workspace Specific\*\***: - Google Apps Scripts (automation/integration tools) - Marketplace Apps (pre-built integrations) - Drive Third-Party Integrations (apps connected to Drive) - AI File Sharing Signals (data leaving organization via AI services)

**\*\*Universal\*\***: - MCP Agents (Model Context Protocol agents - autonomous execution) - AI Tools (ChatGPT, Claude, Gemini, etc.)

### Risk Scoring Algorithm

**\*\*Input Factors\*\***: 1. **\*\*Whitelist Match\*\*** — Is this a known, approved tool? 2. **\*\*MCP Detection\*\*** — Is this an autonomous agent? 3. **\*\*Over-Permissioning\*\*** — Does it have permissions it doesn't use? 4. **\*\*Sensitive Permissions\*\*** — Can it access mail, files, user records? 5. **\*\*Asset Type Signals\*\*** — Is it a risky type (Google Apps Script, etc.)?

**\*\*Risk Level Determination\*\***: - **\*\*HIGH\*\***: MCP agent OR (over-permissioned + sensitive permissions) OR unknown app with sensitive permissions - **\*\*MEDIUM\*\***: Over-permissioned OR sensitive permissions alone - **\*\*LOW\*\***: Approved whitelist app OR minimal permissions

**\*\*Output\*\***: Risk level + reason text explaining why it's classified that way

## 6. Current Features (MVP)

### What's Built (Live)

1. [Done] User authentication (signup, login, password reset) 2. [Done] Microsoft 365 OAuth connection with tenant\_id capture 3. [Done] Google Workspace OAuth with refresh token storage (server-side) 4. [Done] Full scanner for both Microsoft and Google environments 5. [Done] Whitelist-based risk scoring with over-permissioning detection 6. [Done] PDF report generation with findings and recommendations 7. [Done] Dashboard with scan overview and asset inventory 8. [Done] Report download functionality 9. [Done] Multi-tenant support with customer isolation

### What's Partially Built

- Settings page (basic account info, environment re-connection) - Search/filter in asset inventory

## 7. Planned Features and Future Roadmap

### Phase 2: Intelligence & Automation

- **\*\*Behavioral Analytics\*\***: Track permission usage trends over time (not just 30-day snapshot) - **\*\*Anomaly Detection\*\***: Alert when an app suddenly increases permission usage - **\*\*Automated Remediation\*\***: Template workflows to revoke permissions or disable apps - **\*\*Policy Enforcement\*\***: Define organizational policies (no shadow AI, only approved tools, etc.) - **\*\*Scheduled Rescans\*\***: Periodic scans (weekly/monthly) instead of one-time - **\*\*Continuous Monitoring\*\***: Real-time alerts instead of batch scanning

### Phase 3: Broader Coverage

- **\*\*Slack Integration\*\***: Discover apps connected to Slack workspace - **\*\*GitHub Enterprise\*\***: Scan for AI-powered developer tools and automation - **\*\*Salesforce\*\***: Check for AI tools accessing customer data - **\*\*Generic SaaS Discovery\*\***: Track all third-party app integrations across platforms - **\*\*Email Analysis\*\***: Scan for forwarding rules/delegates to external addresses (data exfiltration risk)

### Phase 4: Advanced Risk Management

- **Custom Risk Policies**: Define risk rules specific to organization - **Data Classification**: Identify which apps access sensitive data types - **Access Reviews**: Workflow for security teams to review and approve high-risk access - **Audit Trail**: Track all remediation actions for compliance reporting - **Risk Trending**: Dashboard showing risk improvements over time

## Phase 5: Enterprise Expansion

- **SIEM Integration**: Send alerts to Splunk, Datadog, etc. - **API for Third-Party Systems**: Allow other tools to query Sentinel AI findings - **White-Label Option**: Resell platform to MSPs/resellers - **Managed Service**: Managed security reviews + recommendation implementation - **Industry-Specific Reports**: Pre-built reports for healthcare, finance, etc.

## Phase 6: AI Agent Governance (Long-term)

- **Agent Inventory**: Full catalog of custom AI agents deployed - **Agent Permissions Audit**: What data can each agent access? - **Agent Update Tracking**: Know when agents are modified/updated - **Fine-Grained Controls**: Limit agent access to specific data/actions - **Agent Attestation**: Prove to regulators that agents are governed

# 8. Business Model

## Revenue Model

- **Per-Scan SaaS**: Monthly subscription based on organization size/frequency - **Pilot Approach**: Free initial scan to get customers in the door - **Enterprise**: Negotiated pricing for large organizations with custom requirements

## Sales Motion

1. Inbound from companies worried about AI control/compliance 2. Outreach to CISOs and security leaders at enterprises 3. Integration with MSPs (managed security providers)

## Market Size

- Target: Enterprise organizations (1000+ employees) - Pain: AI tool sprawl, compliance risk, security blind spot - Urgency: High (regulatory pressure, CEO/board focus on AI governance)

## 9. Regulatory Context

### Compliance Mappings

**\*\*EU AI Act\*\***: - Classification of AI system usage in organization - Assessment of risky AI systems - Governance and documentation requirements

**\*\*SOC 2 Type II\*\***: - Change management (track app additions/permissions) - Access control (verify permissions match business need) - Monitoring (detect unauthorized tool installation)

**\*\*GDPR\*\***: - Data processing agreements (is data leaving organization to AI SaaS?) - Processing activity records (what data do apps access?)

**\*\*HIPAA\*\*** (Healthcare): - Business associate agreements (is AI tool HIPAA-certified?) - Access logs (who accessed patient data via AI?)

**\*\*PCI DSS\*\*** (Payment): - Approved vs. unapproved tools in payment systems - Access control to cardholder data

### Sentinel AI's Role

- Provides visibility (what apps exist, what data they access) - Generates audit trail (for compliance reviews) - Produces compliance report (ready for auditor review) - NOT a compliance guarantee (customer still responsible for remediation)

## 10. Technical Stack Summary

### Backend (Scanner)

- **\*\*Language\*\***: Python 3.x - **\*\*APIs\*\***: Microsoft Graph, Google Workspace Admin API - **\*\*Authentication\*\***: OAuth 2.0 (delegated permissions model) - **\*\*Database\*\***: Supabase PostgreSQL - **\*\*Reports\*\***: PDF generation library - **\*\*Deployment\*\***: Likely AWS Lambda or containerized

### Frontend (Website)

- **\*\*Framework\*\***: Next.js 15 (App Router) - **\*\*Language\*\***: TypeScript - **\*\*Database\*\***: Supabase (managed PostgreSQL) - **\*\*Auth\*\***: Supabase Auth - **\*\*Deployment\*\***: Vercel - **\*\*Styling\*\***: Inline CSS (consistent dark navy)



theme)

## Infrastructure

- **Hosting**: Vercel (website) + Supabase (database/auth/storage) - **Storage**: Supabase Storage for PDF reports - **Environment Variables**: Supabase URL, API keys, OAuth client IDs/secrets, Azure/Google API credentials - **Monitoring**: Vercel logs, Supabase dashboard

## 11. Key Implementation Decisions

### Why OAuth Delegation Model?

- **Zero Software Install**: No endpoint agent needed - **Real Permissions**: Uses actual API permissions, not reverse-engineered - **Audit Trail**: Graph API logs provide usage data - **Compliance-Ready**: Auditors trust OAuth over third-party connectors

### Why Whitelist-Based Scoring?

- **Reduce False Positives**: Known safe tools (GitHub Copilot, approved ChatGPT) marked LOW automatically - **Context Aware**: Same permission has different risk for different apps - **Extensible**: Can add customer-specific whitelist entries

### Why Dual-Platform (Microsoft + Google)?

- **Covers 90%+ of Enterprise**: These are the dominant cloud platforms - **Different Risk Profiles**: MS 365 has more app registration, Google has more script/integration points - **One Report**: Customer gets complete picture in one place (vs. running separate tools)

### Why PDF Report?

- **Compliance Standard**: Auditors expect documentation - **Archiving**: PDF is immutable, good for audit trails - **Sharing**: Easy to share with board/executives without granting access - **Professional**: Demonstrates credibility vs. raw data export

## 12. How Models Should Understand the Codebase

## Key Files to Reference

**\*\*Understanding the Scanner Flow\*\***: - ``scanner/run_scan.py`` — Orchestrator, entry point for automated scanning - ``scanner/db.py`` — Database operations, credential storage - ``scanner/microsoft.py`` — Microsoft environment scanning logic - ``scanner/google.py`` — Google environment scanning logic - ``scanner/risk_scorer.py`` — Risk classification algorithm

**\*\*Understanding the Website\*\***: - ``website/app/page.tsx`` — Marketing homepage - ``website/app/dashboard/page.tsx`` — Customer dashboard structure - ``website/app/auth/login`` — User authentication - ``website/components/dashboard/*`` — Reusable dashboard components - ``website/lib/auth/state.ts`` — OAuth state management

**\*\*Understanding the Data Model\*\***: - Supabase schema shows customer/user/scan/asset relationships - Row-level security controls multi-tenancy - Scan results flow from scanner -> database -> dashboard display

## When Modifying Code

1. **\*\*Understanding Context\*\***: Reference this document to know *why* a feature exists 2. **\*\*Compliance Implications\*\***: If changing data collection, consider what compliance teams need 3. **\*\*Multi-Tenancy\*\***: Any changes must respect customer isolation 4. **\*\*OAuth Security\*\***: State parameters, redirect URIs, credential storage are critical 5. **\*\*Risk Scoring\*\***: Changes to scoring logic affect compliance audits

## 13. Glossary

- **\*\*MCP\*\***: Model Context Protocol — standard for AI agents to access external tools/data - **\*\*Shadow AI\*\***: Unapproved or uncontrolled AI tools used by employees - **\*\*Service Principal\*\***: Application identity in Azure AD (used for automation) - **\*\*OAuth State\*\***: HMAC-signed parameter preventing CSRF attacks in OAuth flows - **\*\*Whitelist\*\***: Database of known, pre-classified applications with risk overrides - **\*\*Over-Permissioned\*\***: App has permissions it doesn't actually use - **\*\*Audit Log\*\***: Historical record of actions in Microsoft Graph or Google Workspace - **\*\*Risk Scoring\*\***: Algorithm assigning HIGH/MEDIUM/LOW risk to each AI tool - **\*\*Compliance Mapping\*\***: Linking findings to regulatory frameworks (EU AI Act, SOC 2, etc.)

## 14. Important Constraints and Considerations

### Security

- Never log or store actual data accessed by apps (only permission types and usage counts) - OAuth tokens are sensitive — store securely (Supabase encrypted columns) - HMAC signing on OAuth state prevents token

hijacking - Refresh tokens rotated automatically by OAuth providers

## **Performance**

- Scanner should complete within 24 hours (goal is near-realtime, but scanning millions of assets takes time) - Dashboard should load quickly (cached summary stats, lazy-load detailed asset lists) - Report generation is async (user doesn't wait; email/notification when ready)

## **Accuracy**

- Risk scoring intentionally avoids false negatives (better to flag and let customer decide) - Whitelist must be maintained by security experts (not automated) - Over-permissioning detection uses 30-day rolling window (accounts for quarterly reports, etc.)

## **Scalability**

- Multi-tenant design supports 1000s of customers - Supabase handles PostgreSQL scaling - Scanner can run in parallel for multiple customers - PDF generation optimized for large asset lists (50+ apps)

This document is maintained for AI models working on the Sentinel AI codebase. Update when major features are added, architectural changes occur, or roadmap items shift.

Generated: April 22, 2026 at 12:10 PM | Document Version 1.0 - For AI Model Context